DNSSEC

Autenticar las respuestas DNS

📧 José Domingo Muñoz

🏫 IES Gonzalo Nazareno · Dos Hermanas

📚 SRI · Servicios de Red e Internet

El problema: DNS no se autentica

- Una respuesta DNS **no demuestra** que venga de quien dice
- Un atacante puede **suplantarla** y llevarte a otra IP: **envenenamiento de caché** (*cache poisoning*)
- La respuesta falsa queda guardada en el **recursivo** y la reciben **todos sus clientes** hasta que caduque el TTL

⚠️ DNS no cifra ni firma. **DNSSEC** (*DNS Security Extensions*) añade **autenticidad e integridad**: permite comprobar que la respuesta la ha generado el dueño de la zona y que no se ha modificado. **No cifra** (no da confidencialidad).

Cómo funciona: firmas y claves

El dueño de la zona **firma** sus registros con **criptografía de clave pública**:

REGISTRO	CONTENIDO
DNSKEY	La **clave pública** de la zona
RRSIG	La **firma** de cada conjunto de registros (por ejemplo, los `A` de un nombre)
DS	*Delegation Signer*: **huella** de la clave de la zona hija, guardada en la zona **padre**
NSEC / NSEC3	**Prueba de inexistencia** firmada: demuestra que un nombre *no existe*

- Normalmente hay dos claves: **KSK** (firma las claves, se identifica en el DS) y **ZSK** (firma los registros)
- Un **resolver validador** recalcula la firma con la DNSKEY y comprueba que coincide

La cadena de confianza

¿Por qué confiar en la clave de `debian.org`? Porque está **avalada por el padre**, y así hasta la raíz:

```
.  (raíz)      clave pública conocida de antemano (trust anchor)
 |  DS de org     firmado por la raíz
 ▼
org            DNSKEY de org, avalada por el DS
 |  DS de debian.org   firmado por org
 ▼
debian.org     DNSKEY de debian.org  →  RRSIG de sus registros
```

- El resolver **sólo necesita conocer la clave de la raíz**: el resto se valida **encadenando** DS → DNSKEY → RRSIG
- Si **toda la cadena** es válida, devuelve la respuesta con el bit `ad` activo
- Si una firma **falla**, devuelve `SERVFAIL`: es mejor no responder que dar un dato falso

Bits de DNSSEC en `dig`

BIT / OPCIÓN	SIGNIFICADO
`ad`	*Authenticated Data*: datos **validados con DNSSEC**
`cd`	*Checking Disabled*: el cliente pide **no validar** (`dig +cd`)
`do` / `+dnssec`	*DNSSEC OK*: el cliente pide los **RRSIG** junto con la respuesta

DNSSEC con `dig`

```
$ dig +dnssec debian.org
;; flags: qr rd ra ad;                    ← ad: validado
debian.org.   172  IN  A      151.101.2.132
debian.org.   172  IN  RRSIG A 8 2 300 20261211013633 20261101011742 29026 debian.org. NXTIX…

$ dig DS debian.org +short
40756 8 2 BBE42151B1A41EFC1F7E6D74D86E601D55051D2B9EB99B1CD0CEAA6E2A5618F5

$ dig DNSKEY debian.org +short
256 3 8 AwEAAaFKOvqD3ZPE/…        ← 256 = ZSK
257 3 8 AwEAAcOt7qF88Cx7…         ← 257 = KSK
```

- **`+dnssec`** pide los registros `RRSIG` junto con la respuesta
- El `RRSIG` indica algoritmo, validez (fechas de inicio y caducidad) y el *key tag* de la clave que firma

Un fallo de validación

`dnssec-failed.org` es un dominio con la firma **rota a propósito** para probar los validadores:

```
$ dig dnssec-failed.org
;; ⟶»HEADER«⟵ opcode: QUERY, status: SERVFAIL
;; flags: qr rd ra;            ← sin ad
```

```
$ dig +cd dnssec-failed.org     ← cd: «no valides»
;; ⟶»HEADER«⟵ opcode: QUERY, status: NOERROR
```

ℹ️ El nombre existe y el servidor tiene la IP, pero el **resolver validador la descarta** porque no puede comprobar la firma. Con `+cd` se desactiva la validación y sí responde.

La firma de la zona

Firmar una zona consiste en **generar las claves** y **publicar** DNSKEY, RRSIG y NSEC en ella, **renovando las firmas** antes de que caduquen.

1. Generar las claves **KSK** y **ZSK**
2. Firmar todos los conjuntos de registros → aparecen los **RRSIG**
3. Publicar el **DS** (huella de la KSK) en la **zona padre**: sin DS, **no hay cadena de confianza**
4. Mantener la zona: las firmas **caducan** y las claves se **rotan**

> ℹ️ En `bind9` moderno la firma y la rotación son **automáticas**: la zona se asocia a una *política de firma* (`dnssec-policy`) y bind gestiona claves y firmas. Se verá en los ejercicios.

¿Quién firma? Nuestro escenario

Tenemos **dos servidores DNS** con papeles distintos:

DNS EXTERNO (PROVEEDOR)

- Aloja la **zona pública** del dominio
- El proveedor suele ofrecer **firmar con un clic**
- Hay que publicar el **DS** en el **registrador** del dominio, que lo sube a la zona padre
- Si el **registrador y el proveedor** son distintos, el DS se copia a mano

NUESTRO BIND (LOCAL)

- Autoridad de las zonas **internas** (`.lan`, vista interna…)
- Como **recursivo**, **valida** las respuestas de Internet (`dnssec-validation`)
- Firmar nuestra zona sólo tiene sentido si hay **DS en el padre**: en zonas internas o delegadas a mano **no hay cadena de confianza**

DNSSEC en nuestras vistas

	VISTA PÚBLICA (INTERNET)	VISTA INTERNA (INTRANET)
Autoridad	**Proveedor** (CDMON)	**Nuestro bind**
Firma	La puede firmar el proveedor + **DS** en el registrador	Normalmente **sin firmar**
Validación	La hacen los **recursivos** de los clientes	La hace **nuestro recursivo**

⚠️ Si el nombre **interno** existe también en Internet pero con otra IP (*split-horizon*), un validador que lo comprobara con DNSSEC público **fallaría**. Por eso nuestro recursivo no valida las zonas sobre las que tiene autoridad.

ℹ️ Hoy `gonzalonazareno.org` **no está firmado**: no hay registro `DS` en `org`. Es lo habitual en la mayoría de dominios.

SRI · UNIDAD 3 — DNSSEC

¡Gracias!

DNSSEC

📧 José Domingo Muñoz 🏫 IES Gonzalo Nazareno · Dos Hermanas 📚 SRI